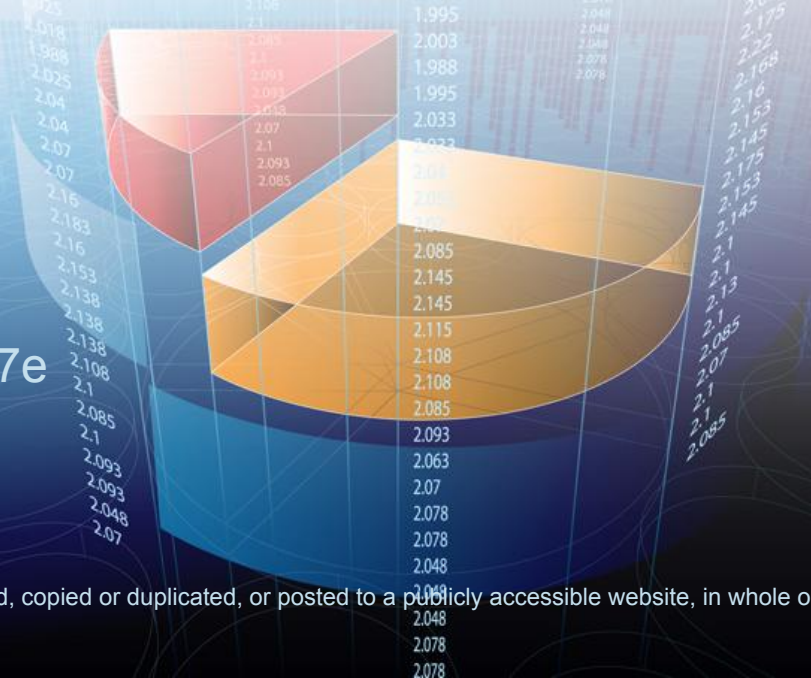
Chapter 15
IT Controls Part I: Sarbanes-Oxley & IT Governance



Accounting Information Systems, 7e

James A. Hall

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Objectives for Chapter 15

- Understand the key features of Sections 302 and 404 of the Sarbanes-Oxley Act.
- Understand management and auditor responsibilities under Sections 302 and 404.
- Understand the risks of incompatible functions and how to structure the IT function.
- Be familiar with the controls and precautions required to ensure the security of an organization's computer facilities.
- Understand the key elements of a disaster recovery plan.
- Be familiar with the benefits, risks and audit issues related to IT Outsourcing.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Sarbanes-Oxley Act

- The 2002 Sarbanes-Oxley (SOX) Act established new corporate governance rules
  - Created company accounting oversight board
  - Increased accountability for company officers and board of directors
  - Increased white collar crime penalties
  - Prohibits a company's external audit firms from designing and implementing financial information systems

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

SOX Section 302

- Section 302—in quarterly and annual financial statements, management must:
  - certify the internal controls (IC) over financial reporting
  - state responsibility for IC design
  - provide reasonable assurance as to the reliability of the financial reporting process
  - disclose any recent material changes in IC

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

SOX Section 404

- Section 404—in the annual report on IC effectiveness, management must:
  - state responsibility for establishing and maintaining adequate financial reporting IC
  - assess IC effectiveness
  - reference the external auditors' attestation report on management's IC assessment
  - provide explicit conclusions on the effectiveness of financial reporting IC
  - identify the framework management used to conduct their IC assessment, e.g., COBIT

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IT Controls & Financial Reporting

- Modern financial reporting is driven by information technology (IT)
- IT initiates, authorizes, records, and reports the effects of financial transactions.
  - Financial reporting IC are inextricably integrated to IT.

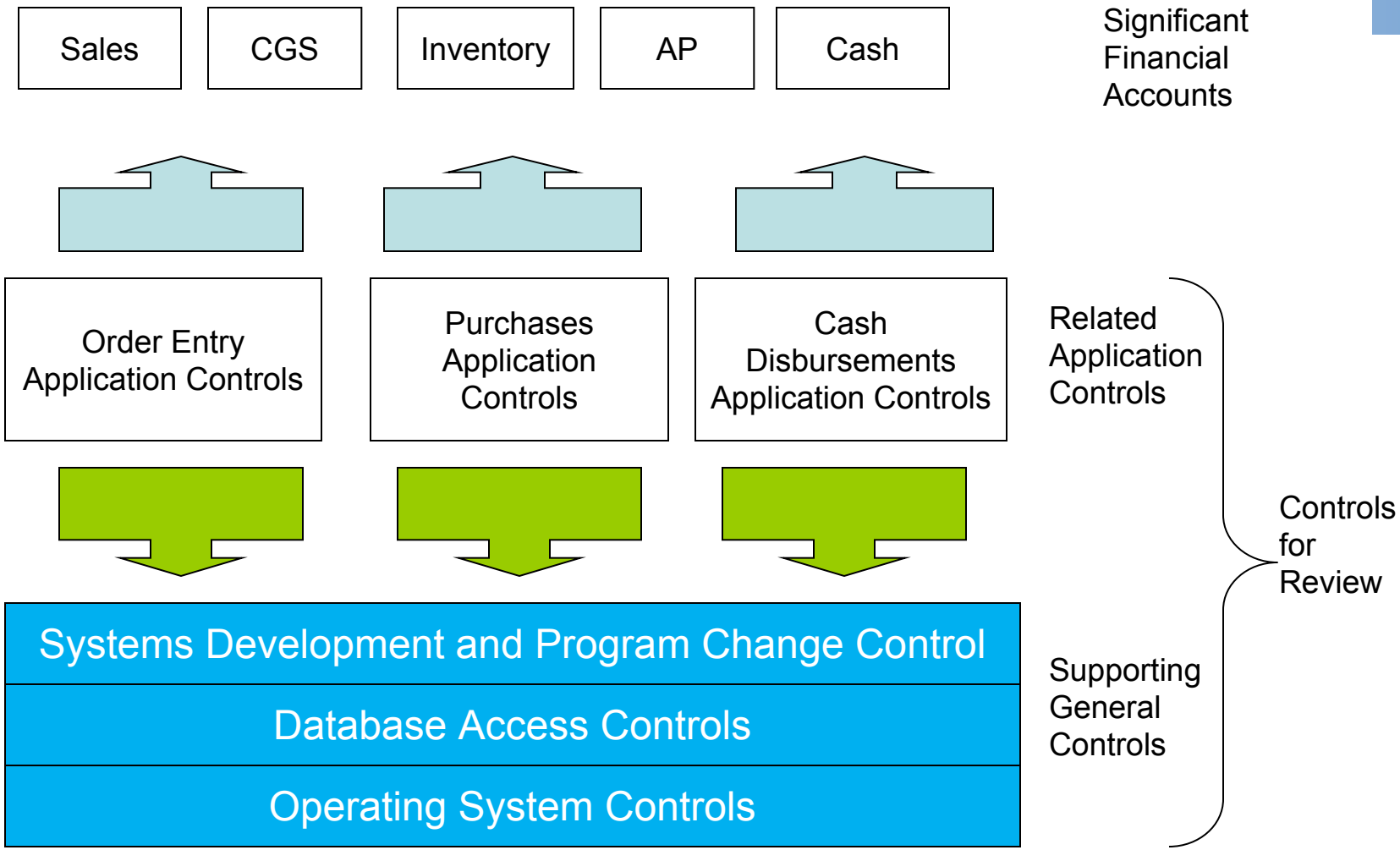
©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IT Controls & Financial Reporting

- **COSO** identifies two groups of IT controls:
  - ***application controls*** – apply to specific applications and programs, and ensure data validity, completeness and accuracy
  - ***general controls*** – apply to all systems and address IT governance and infrastructure, security of operating systems and databases, and application and program acquisition and development

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

IT Controls & Financial Reporting



©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

SOX Audit Implications

- Pre-SOX, audits did not require IC tests.
  - Only required to be familiar with client's IC
  - Audit consisted primarily of substantive tests
- SOX – radically expanded scope of audit
  - Issue new audit opinion on management's IC assessment
  - Required to test IC affecting financial information, especially IC to prevent fraud
  - Collect documentation of management's IC tests and interview management on IC changes

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Types of Audit Tests

- *Tests of controls* – tests to determine if appropriate IC are in place and functioning effectively
- *Substantive testing* – detailed examination of account balances and transactions

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Organizational Structure IC

- *Audit objective* – verify that individuals in incompatible areas are segregated to minimize risk while promoting operational efficiency
- IC, especially segregation of duties, affected by which of two organizational structures applies:
  - *Centralized model*
  - *Distributed model*

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Organizational Chart of a Centralized Information Technology Function

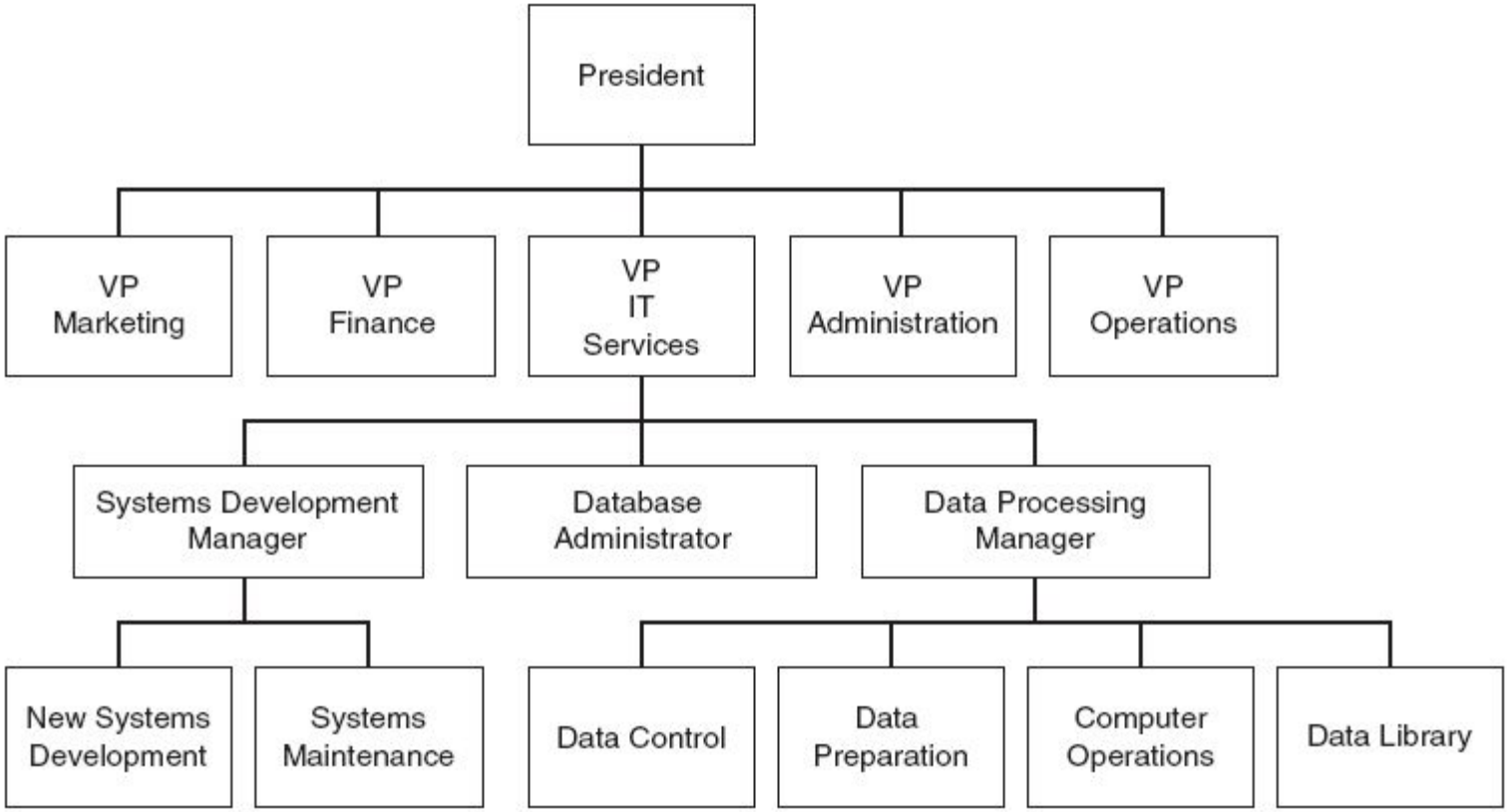


Figure 15-3

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Distributed Organization with Corporate Information Technology Function

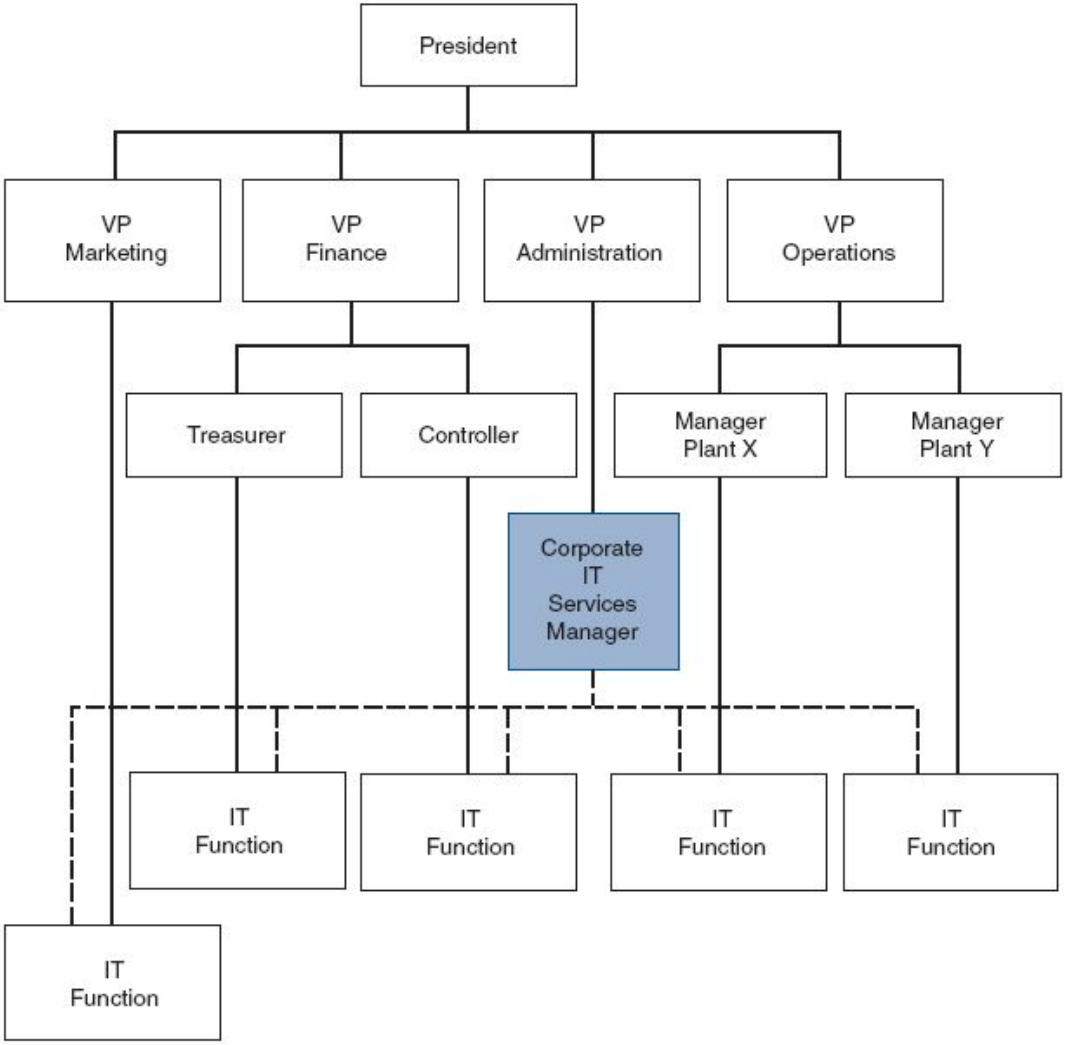


Figure 15-5

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Segregation of Duties

- Transaction authorization is separate from transaction processing.
- Asset custody is separate from record-keeping responsibilities.
- The tasks needed to process the transactions are subdivided so that fraud requires collusion.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Segregation of Duties Objectives

Nested Control Objectives for Transactions

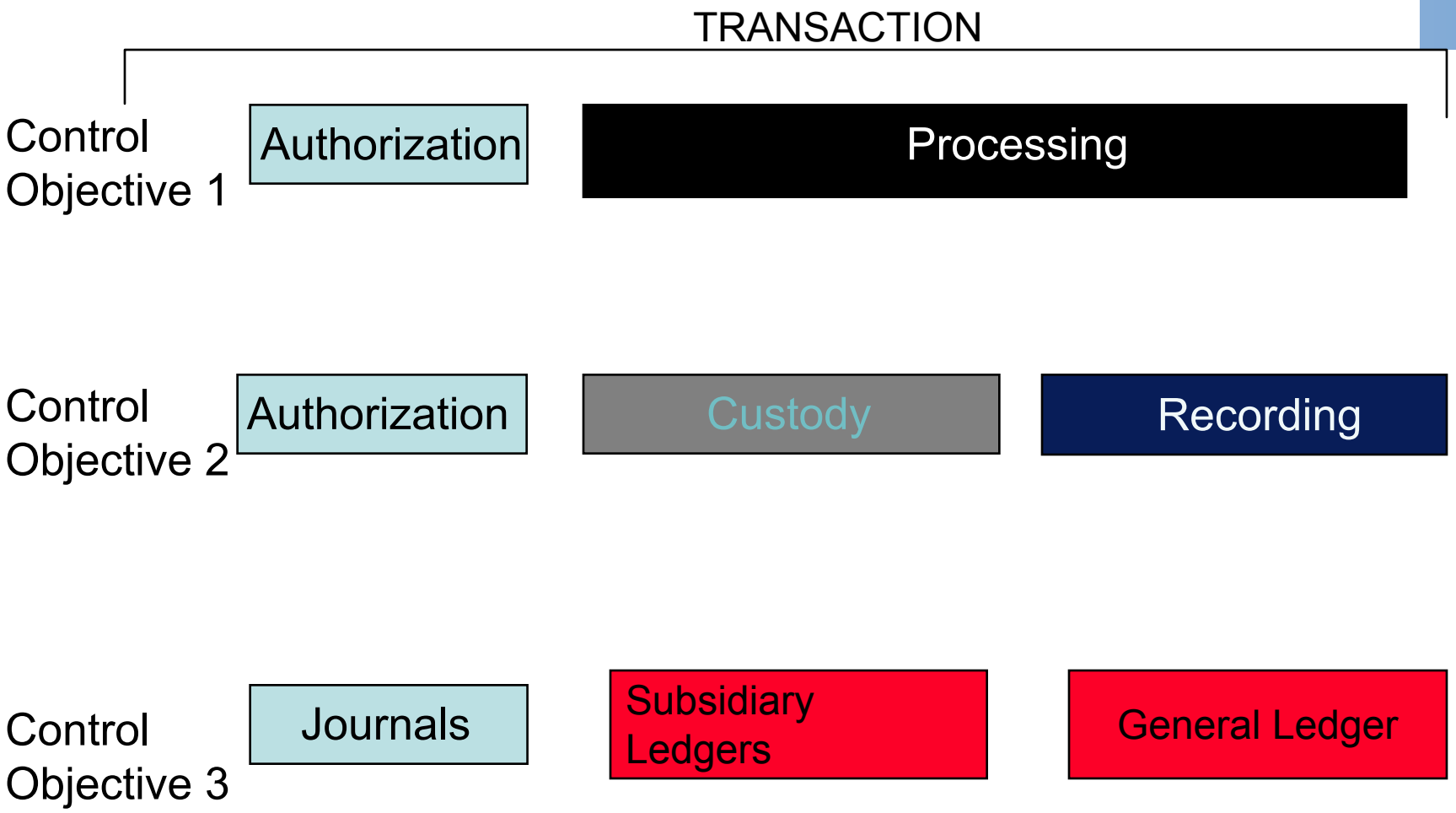


Figure 3-4

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Centralized IT Structure

- Critical to segregate:
  - systems development from computer operations
  - database administrator (DBA) from other computer service functions
    - DBA's authorizing and systems development's processing
    - DBA authorizes access
  - maintenance from new systems development
  - data library from operations

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Distributed IT Structure

- Despite its many advantages, important IC implications are present:
  - incompatible software among the various work centers
  - data redundancy may result
  - consolidation of incompatible tasks
  - difficulty hiring qualified professionals
  - lack of standards

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Organizational Structure IC

- A corporate IT function alleviates potential problems associated with distributed IT organizations by providing:
  - central testing of commercial hardware and software
  - a user services staff
  - a standard-setting body
  - reviewing technical credentials of prospective systems professionals

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Audit Procedures

- Review the corporate policy on computer security
  - Verify that the security policy is communicated to employees
- Review documentation to determine if individuals or groups are performing incompatible functions
- Review systems documentation and maintenance records
  - Verify that maintenance programmers are not also design programmers

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Audit Procedures

- Observe if segregation policies are followed in practice.
  - E.g., check operations room access logs to determine if programmers enter for reasons other than system failures
- Review user rights and privileges
  - Verify that programmers have access privileges consistent with their job descriptions

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Computer Center IC

Audit objectives:

- physical security IC protects the computer center from physical exposures
- insurance coverage compensates the organization for damage to the computer center
- operator documentation addresses routine operations as well as system failures

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Computer Center IC

Considerations:

- man-made threats and natural hazards
- underground utility and communications lines
- air conditioning and air filtration systems
- access limited to operators and computer center workers; others required to sign in and out
- fire suppression systems installed
- fault tolerance
  - redundant disks and other system components
  - backup power supplies

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Audit Procedures

- Review insurance coverage on hardware, software, and physical facility
- Review operator documentation, *run manuals*, for completeness and accuracy
- Verify that operational details of a system's internal logic are not in the operator's documentation

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Disaster Recovery Planning

- Disaster recovery plans (DRP) identify:
  - actions before, during, and after the disaster
  - disaster recovery team
  - priorities for restoring critical applications
- *Audit objective* – verify that DRP is adequate and feasible for dealing with disasters

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Disaster Recovery Planning

- Major IC concerns:
  - second-site backups
  - critical applications and databases
    - including supplies and documentation
  - back-up and off-site storage procedures
  - disaster recovery team
  - testing the DRP regularly

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Second-Site Backups

- **Empty shell** - involves two or more user organizations that buy or lease a building and remodel it into a computer site, but without computer equipment
- **Recovery operations center** - a completely equipped site; very costly and typically shared among many companies
- **Internally provided backup** - companies with multiple data processing centers may create internal excess capacity

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

DRP Audit Procedures

- Evaluate adequacy of second-site backup arrangements
- Review list of critical applications for completeness and currency
- Verify that procedures are in place for storing off-site copies of applications and data
  - Check currency back-ups and copies

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

DRP Audit Procedures

- Verify that documentation, supplies, etc., are stored off-site
- Verify that the disaster recovery team knows its responsibilities
  - Check frequency of testing the DRP

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Benefits of IT Outsourcing

- Improved core business processes
- Improved IT performance
- Reduced IT costs

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Risks of IT Outsourcing

- Failure to perform
- Vendor exploitation
- Costs exceed benefits
- Reduced security
- Loss of strategic advantage

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

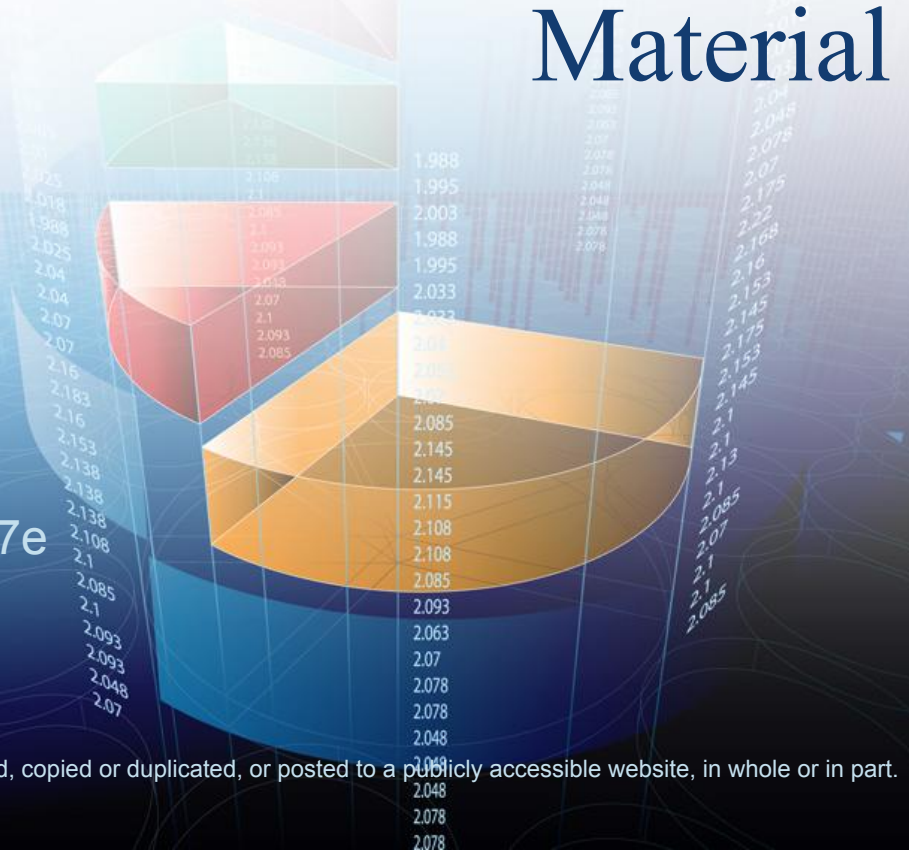
Audit Implications of IT Outsourcing

- Management retains SOX responsibilities
- SAS No. 70 report or audit of vendor will be required

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

From Appendix

Audit Background Material



Accounting Information Systems, 7e

James A. Hall

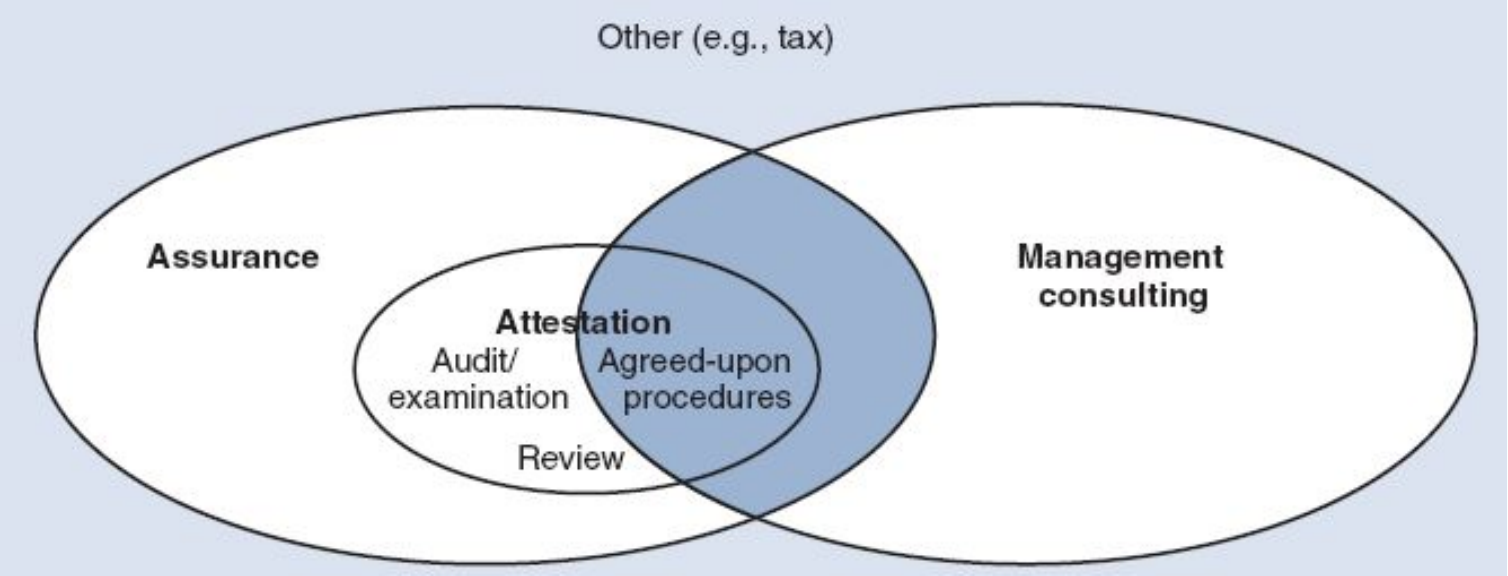
©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Attestation versus Assurance

- Attestation:
  - practitioner is engaged to issue a written communication that expresses a conclusion about the reliability of a written assertion that is the responsibility of another party.
- Assurance:
  - professional services that are designed to improve the quality of information, both financial and non-financial, used by decision-makers
  - includes, but is not limited to attestation

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Attest and Assurance Services



Source: Based on the AICPA *Special Committee Report on Assurance Services.*

Figure 15-8

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

What is an External Financial Audit?

- An independent attestation by a professional (CPA) regarding the faithful representation of the financial statements
- Three phases of a financial audit:
  - familiarization with client firm
  - evaluation and testing of internal controls
  - assessment of reliability of financial data

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Generally Accepted Auditing Standards (GAAS)

General Standards	Standards of Field Work	Reporting Standards
1. The auditor must have adequate technical training and proficiency.	1. Audit work must be adequately planned.	1. The auditor must state in the report whether financial statements were prepared in accordance with generally accepted accounting principles.
2. The auditor must have independence of mental attitude.	2. The auditor must gain a sufficient understanding of the internal control structure.	2. The report must identify those circumstances in which generally accepted accounting principles were not applied.
3. The auditor must exercise due professional care in the performance of the audit and the preparation of the report.	3. The auditor must obtain sufficient, competent evidence.	3. The report must identify any items that do not have adequate informative disclosures.
		4. The report shall contain an expression of the auditor's opinion on the financial statements as a whole.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Auditing Management's Assertions

MANAGEMENT ASSERTION	AUDIT OBJECTIVE	AUDIT PROCEDURE
Existence or Occurrence	Inventories listed on the balance sheet exist.	Observe the counting of physical inventory.
Completeness	Accounts payable include all obligations to vendors for the period.	Compare receiving reports, supplier invoices, purchase orders, and journal entries for the period and the beginning beginning of the next period.
Rights and Obligations	Plant and equipment listed in the balance sheet are owned by the entity.	Review purchase agreements, insurance insurance policies, and related documents.
Valuation or Allocation	Accounts receivable are stated at net realizable value.	Review entity's aging of accounts and evaluate the adequacy of the allowance for uncorrectable accounts.
Presentation and Disclosure	Contingencies not reported in financial accounts are properly disclosed in footnotes.	Obtain information from entity lawyers about the status of litigation and estimates of potential loss.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

External versus Internal Auditing

- **External auditors –** represent the interests of third party stakeholders
- **Internal auditors –** serve an independent appraisal function within the organization
  - Often perform tasks which can reduce external audit fees and help to achieve audit efficiency

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

What is an IT Audit?

Since most information systems employ IT, the IT audit is a critical component of all external and internal audits.

- IT audits:
  - focus on the computer-based aspects of an organization's information system
  - assess the proper implementation, operation, and control of computer resources

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Elements of an IT Audit

- Systematic procedures are used
- Evidence is obtained
  - tests of internal controls
  - substantive tests
- Determination of materiality for weaknesses found
- Prepare audit report & audit opinion

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Phases of an IT Audit

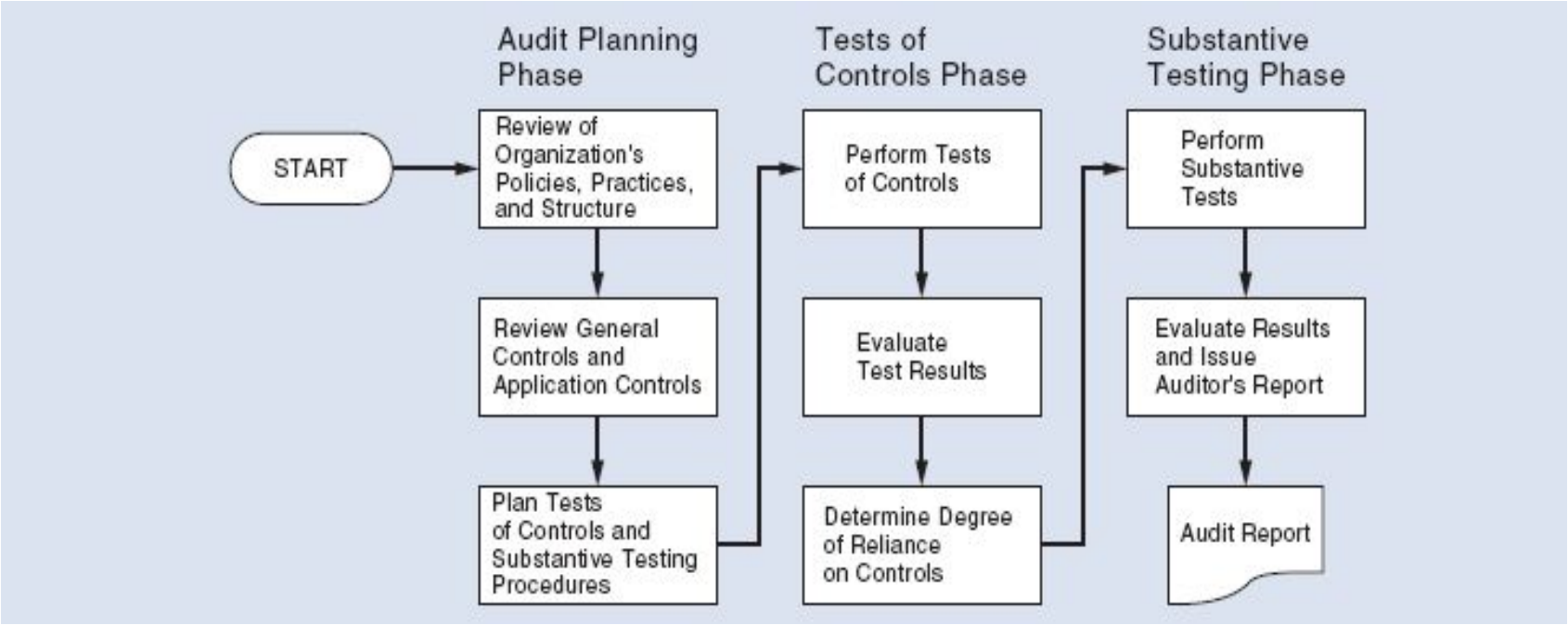


Figure 15-9

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Audit Risk is...

the ***probability*** the auditor will issue an ***unqualified*** (clean) opinion when in fact the financial statements are ***materially*** misstated.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Three Components of Audit Risk

- **Inherent risk** – associated with the unique characteristics of the business or industry of the client
- **Control risk** – the likelihood that the control structure is flawed because controls are either absent or inadequate to prevent or detect errors in the accounts
- **Detection risk** – the risk that errors not detected or prevented by the control structure will also not be detected by the auditor

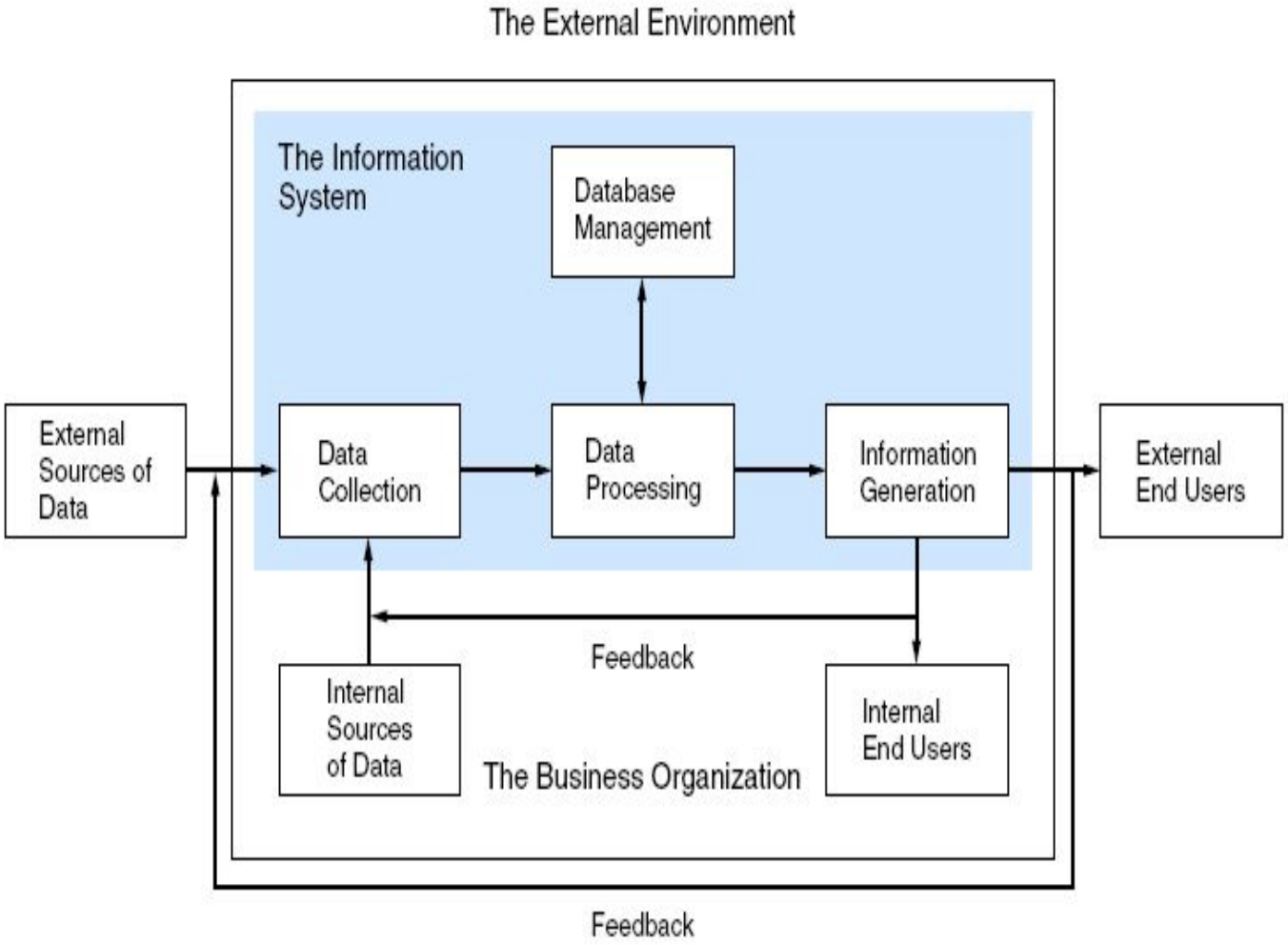
©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Computer Fraud Schemes

- Theft, misuse, or misappropriation of assets by altering computer-readable records and files
- Theft, misuse, or misappropriation of assets by altering logic of computer software
- Theft or illegal use of computer-readable information
- Theft, corruption, illegal copying or intentional destruction of software
- Theft, misuse, or misappropriation of computer hardware

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Using the general IS model, explain how fraud can occur at the different stages of information processing?



©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Data Collection Fraud

- This aspect of the system is the **most vulnerable** because it is relatively easy to change data as it is being entered into the system.
- Also, the GIGO (garbage in, garbage out) principle reminds us that if the input data is inaccurate, processing will result in inaccurate output.

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Data Processing Fraud

Program Frauds

- altering programs to allow illegal access to and/or manipulation of data files
- destroying programs with a virus

Operations Frauds

- misuse of company computer resources, such as using the computer for personal business

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Database Management Fraud

- Altering, deleting, corrupting, destroying, or stealing an organization's data
- Oftentimes conducted by disgruntled or ex-employee

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.

Information Generation Fraud

Stealing, misdirecting, or misusing computer output

Scavenging

- searching through the trash cans on the computer center for discarded output (the output should be shredded, but frequently is not)

©2011 Cengage Learning. All Rights Reserved. May not be scanned, copied or duplicated, or posted to a publicly accessible website, in whole or in part.